

Glossary

127.0.0.1 (localhost): a web address that always means "this computer". The dashboard answers only there, so nobody else on the network can open it. Example: `http://127.0.0.1:5000`.

Bandit: a free, open-source checker for Python code. SecureGate runs three of its checks, for passwords written in the code (B105, B106, B107). Example: `password = "hunter2"`.

CI (continuous integration): a service that runs checks automatically every time someone proposes a change to a project. Example: GitHub shows a red cross on a pull request when a check fails. SecureGate runs there as the merge gate, the `secret-gate` check.

Code owners: the people GitHub asks to review a pull request that changes certain files, listed in `.github/CODEOWNERS`. A ruleset can make their review required.

Commit: a saved snapshot of a project in Git, with a message, an author and a date.

Dashboard: SecureGate's web pages that show a scan report in your browser. It only reads the report and only shows masked values. Example: `make ui`.

Decoy: something that looks like a secret but is not. Example: a 40-character commit hash, or a placeholder.

Demo pull request: a real pull request that SecureGate opens on GitHub to show the merge gate at work, with fake values made at random. Its branch name starts with `demo/`, and it is never merged. Example: `make demo-leak`; `make demo-cleanup` closes them all.

Design token: a named design value, such as a colour or a spacing, kept in one place so the whole design can be changed there. Example: `--color-brand-foreground-1: #5AB0FF` in `tokens.css`, the accent colour of the dashboard.

Entropy: a score for how random a piece of text looks, in bits per character. Example: `aaaa` scores 0; a random key scores about 4 to 6. Scanners use it to tell keys from ordinary words.

Exit code: the number a program gives back when it finishes, so other tools can react. SecureGate: 0 = pass, 1 = something is blocked, 2 = SecureGate could not do its job.

False negative (miss): a real secret that the tool did not report. Example: a database password hidden inside a web address.

False positive (false alarm): something reported as a secret that is not one. Example: a random-looking cache key.

Fingerprint: a code made from a secret that recognizes the same secret again, without storing it. SecureGate mixes in a private key (a method called HMAC), so nobody can work back from the fingerprint to the secret, or test guesses against it. Example: `dcc7b5bb...` (64 characters).

gh (GitHub CLI): GitHub's own command-line program. SecureGate uses it to open and close demo pull requests and to download the merge gate's reports. Example: `gh auth login` signs it in once.

Git history: every commit ever made in a repository. Deleting a line in a new commit does not remove it from the older ones.

Gitleaks: a free, open-source scanner that finds key-shaped text in files and in Git history. SecureGate uses it to find candidates, then decides itself.

Hardcoded: written directly into the code, instead of being loaded from a safe place when the program runs. Example: a Stripe key typed into a Python file.

Live check (validity): asking the provider whether a found key still works. TruffleHog can do it for the services it knows. Example: `verified` means the provider confirmed the key is live; SecureGate then always blocks it (rule 1).

Masking: hiding most of a value before showing it. SecureGate keeps the first 4 and last 4 characters of values with 16 or more characters, like `sk_1****562d`. Shorter values become `****`.

Placeholder: a made-up stand-in value. Example: `YOUR_API_KEY_HERE` or `changeme`.

Policy: the numbered rules in `policy.yaml` that decide block, warn or ignore for each finding. Example: `rule 8: provider-keys` blocks live payment, cloud and GitHub keys.

Pre-commit: the moment just before a change is saved as a commit. A pre-commit check can stop a secret before it ever enters the history. Example: after `make hooks`, every commit first runs `securegate scan . --mode staged`, which checks exactly the changes about to be committed.

Pull request: a request to add a set of commits to the main version of a project. Others can review it, and checks run on it, before it is merged. Example: `make demo-leak` opens one.

Repository (repo): a project folder together with its Git history.

Rotation: replacing a leaked secret with a new one and cancelling the old one, so the leaked copy stops working. It is the only real fix for a leak.

Ruleset: a set of rules that GitHub enforces on branches. Example: "main only changes through a pull request whose `secret-gate` check passed".

Semgrep: a free, open-source code checker that matches patterns in code. SecureGate runs Semgrep's `p/secrets` rules and its own rules for risky handling of secrets, such as printing a token to a log.

SARIF: a standard file format for the results of code checkers. GitHub shows a SARIF file's results in a repository's **Security** tab. Example: `securegate scan --sarif gate.sarif`.

Secret: a password, key or token that gives access to something: money, data, servers or code. Example: a Stripe live key lets you take card payments.

Status check: a test that GitHub runs on a pull request and shows as a green tick or a red cross. A ruleset can make it required. Example: `secret-gate`.

TruffleHog: a free, open-source scanner that finds secrets in Git history, like Gitleaks, and can also ask the provider whether a key still works. SecureGate runs it with `--scanners all`.

Workflow: a list of steps that GitHub Actions runs on GitHub's own computers when something happens, such as a new pull request. Example: `.github/workflows/secret-gate.yml`.